

NETWORK TRAFFIC SNIFFING

Extended Study / Lab Notes

Prepared By	Dhruva
Topic	Packet Sniffing & RDP Traffic Analysis
Primary Tool	Wireshark
Reference Lab	Sniffing Module (Passed — 60%)
Purpose of Notes	Consolidated theory + practical reference for revision

1. Foundational Concepts

1.1 What Is Packet Sniffing?

Packet sniffing is the process of intercepting and logging traffic that passes over a network interface. A sniffer places the network interface card (NIC) into promiscuous mode (or monitor mode on wireless), allowing it to capture frames not addressed to it, not just its own traffic. Sniffing is used for legitimate purposes such as troubleshooting, performance analysis, and security monitoring, but the same technique can be abused for eavesdropping if traffic is unencrypted.

- **Passive sniffing:** capturing traffic on a hub-based or mirrored/SPAN network without injecting any packets — purely observational.
- **Active sniffing:** involves techniques such as ARP spoofing/poisoning to redirect switched traffic through the attacker's or analyst's machine so it can be captured.

1.2 The OSI Model and Where Sniffing Operates

Understanding sniffed traffic requires mapping it back to the OSI (Open Systems Interconnection) model. Wireshark displays each layer as a separate expandable section in the packet details pane.

Layer 2 — Data Link	Ethernet frames, MAC addresses, ARP resolution.
Layer 3 — Network	IP addressing, routing (IPv4/IPv6 headers).
Layer 4 — Transport	TCP/UDP — ports, sequence numbers, flags, reliability.
Layer 7 — Application	The actual protocol payload, e.g. RDP, HTTP, DNS.

In this lab, frames were inspected from Layer 2 (Ethernet source/destination MAC) up through Layer 4 (TCP sequence/ack/window) and into the Layer 7 RDP Fast-Path PDU structure.

1.3 The TCP Three-Way Handshake (Background)

Although the captured frames in this lab were mid-session, it is worth remembering how a TCP conversation such as the RDP session begins, since retransmissions and ACK behaviour only make sense in that context:

1. SYN — client proposes a connection and an initial sequence number.
2. SYN-ACK — server acknowledges and proposes its own initial sequence number.
3. ACK — client acknowledges; the connection is now established and data can flow.

Once established, every subsequent segment carries a Sequence number (position of this segment's first byte in the stream) and an Acknowledgement number (next byte the receiver expects), which is exactly the pattern seen throughout the capture (e.g., Seq=19666, Ack=17457644).

2. Tools & Services Used

2.1 Wireshark

Wireshark is a free, open-source protocol analyzer. It captures traffic via a packet-capture library (WinPcap/Npcap on Windows, libpcap on Linux/macOS) and decodes it using protocol dissectors, presenting three synchronized panes:

- **Packet List:** one row per captured frame — number, time, source, destination, protocol, length, info.
- **Packet Details:** an expandable, layer-by-layer breakdown of the selected frame.
- **Packet Bytes:** the raw hex/ASCII bytes of the frame, with the selected field highlighted.

2.2 Remote Packet Capture Protocol (RPCAP) Service

Windows exposes an optional service — "Remote Packet Capture Protocol v.0 (experimental)" — that allows a Wireshark instance on a different machine to request a live capture feed from the host running the service, without needing to log into that host directly.

Service Name	Remote Packet Capture Protocol v.0 (experimental)
Function	Allows traffic on this machine to be captured from a remote machine
Observed Startup Type	Manual
Observed Status	Running
Log On As	Local System
Security Note	Experimental/legacy component — exposes a capture channel over the network; should be disabled when not actively required and restricted to trusted hosts only.

2.3 RDP (Remote Desktop Protocol) Basics

RDP is Microsoft's proprietary protocol for remote GUI access, built on top of the ITU-T T.120 family of protocols. Key facts relevant to this lab:

- Default port: TCP 3389 (UDP 3389 is also used for RDP's UDP transport extension in modern Windows).
- Two PDU encoding types: Slow-Path (older, more overhead) and Fast-Path (compact, used for frequent updates like pointer movement and screen surface changes).
- Session data is typically encrypted (RDP Security Layer or, preferably, TLS via Network Level Authentication), but Wireshark can still dissect the outer Fast-Path headers even when the payload itself is protected.

3. Detailed Capture Workflow

The following expands the step-by-step process actually followed in the lab, with the reasoning behind each step:

3.1 Preparation

- Confirmed the Remote Packet Capture Protocol service was running on the target host so a remote capture session could be initiated if needed.
- Identified the correct capture interface (eth0) — capturing on the wrong interface is one of the most common reasons a Wireshark capture shows no relevant traffic.

3.2 Capturing

- Started the live capture with no filter first, to confirm traffic was actually flowing (broadcast/ARP/IPv4 noise is a good sanity check).
- Let the capture run while an RDP session was active between 10.10.1.13 and 10.10.1.3, generating a realistic volume of Fast-Path PDU traffic.

3.3 Filtering

Once enough traffic was captured, a display filter was applied to cut through the noise. Useful filters for this type of exercise include:

tcp.port == 3389	Show only RDP traffic (both directions).
ip.addr == 10.10.1.13	Show all traffic to/from a specific host.
tcp.analysis.retransmission	Show only TCP segments Wireshark has flagged as retransmissions.
tcp.flags.push == 1	Show only segments with the PSH flag set (data being pushed up the stack).
rdp	Show frames the RDP dissector has successfully parsed.

3.4 Analysis

- Followed the TCP stream to see the conversation as a continuous exchange rather than isolated frames.
- Expanded the Ethernet, IP, and TCP layers on selected frames to confirm addressing and flags.
- Used Analyze → Expert Information to quickly surface warnings such as retransmissions and malformed packets instead of scrolling manually.

3.5 Validation

- Cross-checked sequence/acknowledgement numbers across consecutive frames to confirm the byte stream was progressing correctly.
- Completed the lab's "Sniffing" assessment module to validate conceptual understanding against the practical capture.

4. Detailed Findings From This Capture

4.1 Host Discovery / ARP

An ARP request/reply pair was observed resolving a third host on the same subnet:

- Request: "Who has 10.10.1.11? Tell 10.10.1.13"
- Reply: "10.10.1.11 is at 00:15:5d:01:80:11" (vendor prefix resolved to Microsoft_01:80:11)

This confirms ARP was actively resolving Layer 2 addresses for Layer 3 destinations on the local subnet, which is expected behaviour before any new host-to-host conversation begins.

4.2 Ethernet Frame Details

Selected frames showed source and destination MAC addresses tied to MS-NLB-PhysServer identifiers — indicating the hosts are members of a Microsoft Network Load Balancing (NLB) cluster. Both addresses had the Locally Administered (LG) bit set, meaning these MAC addresses were assigned by software (typical for NLB virtual MAC addressing) rather than burned in by the manufacturer.

4.3 TCP Behaviour

Observed Ports	42382 (client/dynamic) ↔ 3389 (RDP server)
Flags Seen	ACK, PSH+ACK
Sequence Growth	Seq numbers climbing steadily (e.g., 19666 → 19717), confirming an ongoing, healthy byte stream
Window Sizes	Fluctuating between roughly 25,000–27,500 bytes, adjusted dynamically by the receiver
Anomaly	One TCP Retransmission at frame 7349 (Seq=19683) — the original segment was not acknowledged in time and was resent

4.4 RDP Fast-Path PDU Types Observed

PDU Type	Purpose	Notes From Capture
NewPointer	Defines a new cursor/pointer bitmap	Flagged malformed in this capture
ColorPointer	Colour cursor bitmap update	Flagged malformed in this capture
CachedPointer	References a previously cached pointer	Multiple instances seen; some flagged malformed
PointerPosition	Updates cursor position only	Frequent, small frames
LargePointer	Cursor bitmap exceeding normal size limits	Larger frame size (~4.5 KB) observed
Palette	Colour palette update	Small, infrequent
Synchronize	Synchronizes client/server state	Larger frames (~10-11 KB)
Surface	Screen/surface bitmap update	Largest frames, carries visual data

4.5 Why "Malformed Packet" Appears

A "Malformed Packet" label from Wireshark does not always mean the traffic itself is broken — it often means the dissector could not fully parse the structure it expected, which can happen when:

- TCP segments are reassembled slightly out of order relative to what the RDP dissector expects.
- The capture missed earlier context frames needed to track RDP's internal state machine correctly.
- The PDU uses an extension or edge-case structure the dissector version doesn't fully support.

This is a useful distinction to remember: 'malformed' in Wireshark output is a parsing warning, not automatically a security incident.

5. Extended Glossary

Promiscuous Mode	NIC mode that captures all frames on the segment, not only those addressed to it.
ARP	Address Resolution Protocol — maps an IP address to a MAC address on the local subnet.
MAC Address	Layer 2 hardware address; can be burned-in or locally administered (as with NLB virtual MACs).
PSH (Push)	TCP flag telling the receiver to deliver buffered data to the application immediately.
ACK (Acknowledge)	TCP flag/number confirming receipt of data up to a given byte.
Seq (Sequence Number)	Position of the first byte of this segment within the overall TCP byte stream.
Win (Window Size)	How many bytes the receiver is currently willing to accept before requiring an ACK.
TSval / TSecr	TCP timestamp value/echo-reply, used for round-trip-time estimation and protecting against wrapped sequence numbers.
Retransmission	A segment resent because its original transmission was not acknowledged within the expected time.
Fast-Path PDU	Compact RDP data unit format used for frequent, low-overhead updates (pointer, surface, etc.).
Slow-Path PDU	Older, higher-overhead RDP data unit format, generally used for less frequent, more complex exchanges.
NLB (Network Load Balancing)	Windows Server feature that distributes traffic across a cluster of hosts sharing a virtual MAC/IP.
RPCAP	Remote Packet Capture protocol/service — lets a remote analyzer capture traffic on a host without local access.
Display Filter	A Wireshark expression (e.g., tcp.port == 3389) used to show only matching frames without discarding the rest of the capture.
Capture Filter	A BPF-style filter applied before capture begins, reducing what is written to disk (more restrictive than a display filter).

6. Security Considerations & Best Practices

6.1 Risks Highlighted by This Exercise

- An always-on remote capture service (RPCAP) increases the attack surface — if left running and reachable, it could allow unauthorized traffic capture.
- Unencrypted or weakly configured RDP sessions could allow an attacker performing active sniffing (e.g., via ARP spoofing) to observe session metadata or, in weaker configurations, more.
- Malformed/retransmitted packets are useful indicators to monitor over time — a sudden spike could indicate network problems or, in some cases, interference/tampering.

6.2 Recommended Hardening Steps

- Disable the Remote Packet Capture Protocol service unless it is actively required for a specific, time-boxed task.
- Enforce Network Level Authentication (NLA) and TLS encryption for all RDP endpoints.
- Restrict RDP exposure using firewall rules, VPN-only access, or a jump-host/bastion pattern rather than direct internet exposure.
- Baseline normal retransmission/error rates for critical links so anomalies are easier to spot during future captures.
- Keep Wireshark and its dissectors up to date, since improved parsing reduces false "malformed packet" warnings.

7. Assessment Summary

Module	Sniffing
Result	Passed
Score	60%
Expected Duration	1 hour, 20 minutes
Actual Duration	2 hours, 1 minute

The extended time relative to the expected duration suggests additional time was spent working through the malformed-packet and retransmission findings — a reasonable trade-off given the extra analytical depth it produced.

8. Revision Checklist

- ☐ Re-explain, from memory, the difference between passive and active sniffing.
- ☐ Re-derive the TCP three-way handshake and what Seq/Ack values look like afterwards.
- ☐ List at least five useful Wireshark display filters without looking them up.
- ☐ Explain why a frame might show as 'Malformed Packet' without the traffic being malicious.
- ☐ Describe the difference between RDP Fast-Path and Slow-Path PDUs.
- ☐ Explain the security risk of leaving the Remote Packet Capture Protocol service enabled.

- [] Identify at least two RDP hardening measures (NLA, TLS, firewalling, bastion hosts).
- [] Review Analyze → Expert Information workflow in Wireshark for faster anomaly spotting.